想做一個可以檢查帳號是否合規的小工具，目前想做的步驟如下

實作規劃

先用 terraformer 驗證看看，CIS benchmark 的規則，也順便看一下

- terraformer 可以執行嗎?
- 他具體是怎麼做的?
- 需要拿帳號裡面的哪些資料來檢查我預計要用的 CIS benchmark

接下來確定好，CIS benchmark、需要用到的 aws 資源開始實作

- 將可以取需要的資源的 api 與其相關的錯誤處理或是不同條件的邏輯完成
- 將資源存成 json
- 撰寫 rego (或是參考其他專案的)

最後接起來，將取得的資源，送進 opa 檢查，包成報告輸出

但其實可以先確定規則，目前參考的是 AWS CIS AWS Foundations Benchmark v5.0.0

發現

terraformer 可以執行嗎?

可以，用 v0.8.30 加上 Terraform AWS provider 用 v5

具體是怎麼做的?

準備階段：

- 先執行 `terraform init`，下載並鎖定 `hashicorp/aws` provider plugin
- 找到 provider 後啟動，並透過 Terraform plugin protocol（gRPC）與它溝通

開始列舉服務：

- terraformer 有支援不同 aws 服務的 generator
- 對指定的 region 用 generator 呼叫 List、*Describe*、Get* 等 api 列舉資源 (他是一個一個 region 掃描的)
- 取得 import id 、資源名稱、一些資料...

再透過 provider 補資料：

- 他會先為每個資源建立一份狀態(只有名稱 ID 的狀態)
- 然後透過 gRPC 呼叫 AWS provider 的 ReadResource，像是 Terraform import 後的 refresh (Refresh 是拿雲端的狀態，更新 terraform 存的狀態，用這個狀態比對設定檔並更新)
- 失敗的話好像有另外的處理方式，但我後來沒有追完

最後轉換並輸出：

- 將 state 轉成 Terraform 的資料結構，並按照服務來建立目錄寫出 .tf 檔

實際追完流程之後再想，可能不需要列舉所有的服務，只需要根據 cis 來選擇要列舉哪些服務並檢查就好? 所以目前先將寫好的 rule 用 terraform 掃描出來的資料驗證過 rule 是可以運作的，接下來會減少掃描的工作，不需要像是 Terraformer 一樣全掃，只要針對要檢查的目標掃就好了?

最後驗證

在比對不同來源時發現(Terraform、我自己的 scanner)，Terraformer 在列舉 sg 時會出現故障，後來發現是configCache 是全域變數，第一個 service 建立好之後，後續所有 service 一進 `generateConfig()` 就會直接回傳這分 config，不會處理指定 region 或 profile，所以如果第一份 config 的 Region 是 us-east-1 之後都會拿到 us-east-1 的，又因為它會回傳 0 所以不會出現查詢錯誤，因此結果看起來沒錯，但其實他漏掉了所有 region 的檢查。

最後成果放在 5tmate/cisscan 這個 repo。

CIS benchmark AWS

- CIS AWS Foundations Benchmark in Security Hub CSPM - AWS Security Hub

小結

想做的是一個檢查帳號是否合規的小工具。前面 IaC 階段的檢查只看得到 stack 宣告了什麼，但 CIS 有一半的項目問的是這個帳號現在長什麼樣，那就只能真的去讀帳號。

terraformer 追完之後發現不用照抄。它做的事是列舉、用 provider 把每個資源的狀態補完、再轉回 .tf，但我只需要中間那份資料拿去餵 opa，輸出 .tf 那段是多的，而且 CIS 只關心固定幾種服務，全 region 全服務掃一輪也是多的，之後只要針對要檢查的目標掃就好。

追流程順便撿到一個 bug，configCache 是全域變數，第一個 service 建好 config 之後，後面每個 service 一進 `generateConfig()` 就直接拿到同一份，指定的 region 跟 profile 不會生效。麻煩的是它不會報錯，只會回 0 筆，看起來就像這個 region 沒有這種資源，是比對不同來源才發現 sg 的數字不對。

rule 本身已經用 terraform 掃出來的資料驗證過可以運作，接下來會減少掃描的工作，只掃 CIS 要檢查的目標。

參考資料

- GoogleCloudPlatform/terraformer(v0.8.30)
- Terraform AWS Provider(v5)
- How Terraform Works with Plugins(plugin protocol / gRPC)
- Command: refresh | Terraform
- Importing Infrastructure | Terraform
- CIS Amazon Web Services Foundations Benchmark
- Policy Language | Open Policy Agent